Abstract

Indirect prompt injection can cause an AI application to treat content supplied by an external source as an instruction, with consequences when that application can use tools. We present Trust Boundary Lab, an early HCI security prototype that brings source provenance, requested permission, a rule-based risk explanation, and explicit human confirmation into one pre-action review. We define a scoped research agenda and a reproducible set of eight constructed scenarios. A deterministic comparison of four scripted policies is included as a software check only. Its fixture-level outcomes do not measure user performance, deployment attack rates, or statistical effects. The proposed human study requires ethics approval and has not been run. The novelty claim is provisional pending a systematic review of 2023–2026 work. We present the prototype and preregisterable protocol as research infrastructure, not as a validated defense.

Human-Computer Interaction for Secure AI Tool Usage: A Source-to-Action Review Pattern Against Prompt Injection

Anonymous

Unsubmitted research prototype — 2026

1 Introduction

AI applications that read external content and invoke tools create a trust-boundary problem: text supplied as data may be interpreted as an instruction. Prior technical work demonstrates indirect prompt injection in LLM-integrated applications [1]; whether people can reliably recognize a source-to-action mismatch at the authorization moment remains the motivating HCI question for this project. The question is deliberately scoped to the review decision before a tool call, rather than model alignment or general AI trust.

We contribute an implementable interaction concept, a local simulator, constructed scenario fixtures, and an evaluation protocol. The review surface pairs the initiating request with the source excerpt, source trust class, proposed tool, permission scope, and a reasoned risk indicator. A user can approve or reject the simulated action. Our research questions ask whether provenance and risk rationale improve malicious-call recognition, how scoped confirmation changes false blocks, and what workload trade-offs arise.

The contribution is a candidate design pattern, not an established novel result. A systematic review, independent benchmark comparisons, and human evaluation are outstanding. The repository's current evaluation is deterministic and small; we therefore make no efficacy or statistical-significance claims.

2 Related work and gap

Indirect injection work establishes that untrusted content can influence LLM-integrated applications and their actions [1]. A complete related-work section must also compare agent threat benchmarks, system-level defenses, provenance interfaces, permission dialogs, and usable-security warning studies from 2023–2026. The planned search and screening protocol is in `docs/research_plan.md`. Scholarly-index access returned HTTP 403 in the preparation environment, so database coverage, duplicate-work comparison, and bibliographic metadata have not been independently checked. We explicitly leave novelty unresolved rather than infer it from a partial search.

3 Research questions and hypotheses

RQ1: How do provenance and action-specific explanations affect identification of tool requests induced by untrusted content? **RQ2:** What are the security benefit and workload costs of explicit scoped confirmation? **RQ3:** Which cues support discrimination between benign source material and conflicting instructions?

We hypothesize that combined provenance, permission scope, risk rationale, and confirmation improve malicious-call rejection over a no-intervention condition (H1); risk-only warnings create more false blocks of benign consequential actions than source-to-action review (H2); and intervention increases decision time and workload, with a larger cost for consequential actions (H3). These hypotheses have not been tested with participants.

4 System and design

For a fixture x, the prototype computes an explainable score

$$R(x) = \min\left(100, 8 + 22U(x) + 24C(x) + 16O(x) + 16K(x)\right),$$

where U indicates untrusted provenance, C indicates a consequential permission, O indicates text matching a small set of instruction-override cues, and K indicates data-exposure terms. The policy does not read the fixture attack label. The constants are engineering defaults, not fitted weights or calibrated probabilities. The UI displays the source and action explicitly; the policy layer blocks a call when combined-condition risk is at least 60 or when untrusted content proposes non-read permission. All execution is simulated.

The design patterns are: (1) show provenance adjacent to the proposed action; (2) name the permission and affected destination/data; (3) explain risk factors rather than relying on color alone; (4) require a deliberate choice before consequential execution; and (5) preserve narrow, explicit user authorization. The current prototype implements only fixture-level examples of these patterns and is not a deployable security boundary.

5 Method

The fixture set contains eight hand-authored cases spanning benign reads, explicit user-authorized deletion, an unsent-draft mismatch, malicious external instructions, data disclosure, and a sharing change. Four deterministic policies are compared: automatic approval, a risk threshold, provenance-aware consent, and a combined rule. The baselines are ablations of the prototype logic, not strong learned or production defenses. No generative model is called, and no live tool is invoked.

The evaluation reports attack success rate, defense effectiveness, benign block rate, and decision accuracy over this finite set. Since fixtures are selected and labeled by the authors, they cannot estimate real-world prevalence or generalization. There is no sampling process over attacks or users and thus no inferential significance test. The automated tests validate code behavior, not the hypotheses.

6 Results and evidence status

No human-study results are available. The deterministic scripted output is generated by `trust-boundary-evaluate`; the committed summary artifact is labeled as fixture-only evidence. It will be reported as a reproducibility check and not as a defense-effectiveness experiment. Latency, decision time, workload, trust, user accuracy, and statistical significance remain unmeasured.

7 Proposed user study

We propose a counterbalanced within-subject 2×2 study varying provenance and action-risk/authorization controls, with a no-intervention baseline. Fictional scenarios would be randomly ordered; all calls

would be simulated. Outcomes would include attack acceptance, benign false blocks, decision accuracy, response time, NASA-TLX workload, confidence, and perceived control. The preregistered analysis would use participant and scenario random effects and report estimates with confidence intervals. Sample size must be determined by an a priori power simulation based on pilot estimates. The complete draft protocol is in `docs/user_study_protocol.md`. No ethics approval has been obtained; recruitment and study execution must wait for institutional review and approval.

8 Limitations and conclusion

The present artifact is a small prototype with hand-authored fixtures, deterministic rules, no live agent, no production integrations, no verified systematic review, and no human participants. The risk score is easy to evade. The immediate contribution is a testable interface concept and reproducible evaluation scaffold. The next research steps are to complete and document the systematic review, expand and externally validate scenarios, compare with stronger agent defenses, establish ethics approval, run the preregistered user study, and revise claims from the resulting evidence.

References

[1] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023. Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. arXiv:2302.12173. `https://arxiv.org/abs/2302.12173`.